

Implementation of a Secure DevOps CI/CD Pipeline Using DevSecOps Tools

Shakthi Vel K

Department of Computer Science and Engineering
Global Academy of Technology
Bengaluru, India
shakthivelk1124@gmail.com

Revanth Kumar T S

Department of Computer Science and Engineering
Global Academy of Technology
Bengaluru, India
revanthkumarts123@gmail.com

Sanket

Department of Computer Science and Engineering
Global Academy of Technology
Bengaluru, India
sankethcoding@gmail.com

Vignesh P

Department of Computer Science and Engineering
Global Academy of Technology
Bengaluru, India
palanivignesh31@gmail.com

Abstract—The rapid growth of software development has increased the need for faster and more secure deployment practices. DevOps enables continuous integration and continuous delivery of applications, but security vulnerabilities may arise if security is not integrated into the pipeline. DevSecOps integrates security practices into every phase of the DevOps lifecycle to ensure secure software development and deployment. This paper presents the implementation of a Secure DevOps CI/CD pipeline that integrates security scanning, containerization, and continuous monitoring. The proposed system uses tools such as Git, GitHub, Jenkins, Docker, Kubernetes, Terraform, SonarQube, OWASP ZAP, Trivy, Prometheus, and Grafana to automate the development and security processes. The pipeline detects vulnerabilities early in the development lifecycle and provides continuous monitoring to improve application security and reliability.

Keywords— DevOps, DevSecOps, CI/CD Pipeline, Security Automation, Vulnerability Scanning

I. INTRODUCTION

Modern software development requires rapid deployment, scalability, and continuous delivery of applications. DevOps is a software development methodology that integrates development and operations teams to improve collaboration and automate the software delivery process. Continuous Integration (CI) and Continuous Deployment (CD) pipelines allow organizations to build, test, and deploy applications quickly and efficiently.

However, traditional DevOps pipelines often overlook security concerns, which may lead to vulnerabilities in deployed applications. To address this problem, DevSecOps integrates security practices directly into the DevOps pipeline. By embedding security tools and automated vulnerability scanning into the development lifecycle, organizations can detect and mitigate security risks early.

This paper proposes a Secure DevOps pipeline that integrates security testing tools with automated CI/CD processes. The objective is to enhance the security of software applications while maintaining rapid development and deployment cycles.

A. Secure DevOps Architecture

1) CI/CD Pipeline Integration: A Secure DevOps (DevSecOps) pipeline integrates security practices into every stage of the CI/CD workflow. The development process begins when developers push code to the Git

repository hosted on GitHub. Jenkins automatically triggers the build process and performs continuous integration. Static Application Security Testing (SAST) tools such as SonarQube analyze the source code to detect vulnerabilities early in the development phase.

2) Security Scanning and Deployment: Security scanning tools such as OWASP ZAP and Trivy are integrated into the pipeline to detect vulnerabilities in applications and container images. Docker is used to package applications into containers, ensuring consistent deployment across environments. Kubernetes manages and orchestrates these containers to provide scalability and reliability.

Sl. no	Tool	Category	Purpose
1.	Git	Version Control	Track code changes
2.	Jenkins	CI/CD Tool	Automate build and deployment
3.	Docker	Containerization	Package applications
4.	Kubernetes	Container Orchestration	Manage containers
5.	SonarQube	SAST Tool	Detect code vulnerabilities

a) Monitoring and Logging: It's recommended to write your text in a separate document and then add it to this template once it's complete. When copying text into the template from another document, make sure that the

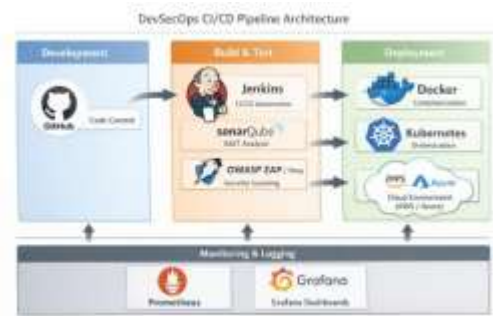


Fig. 1. DevSecOps CI/CD pipeline architecture.

b) Security Best Practices: To maintain a secure DevOps environment, several best practices should be followed:

- Security testing should be integrated into every stage of the CI/CD pipeline.
- Vulnerabilities detected by security tools should be reviewed and fixed by developers.
- Continuous monitoring helps detect abnormal system behavior and potential attacks.

B. Deployment in Cloud Environment

Cloud platforms such as Microsoft Azure or AWS are used to host the infrastructure required for the DevOps pipeline. Infrastructure as Code tools like Terraform automate the provisioning of cloud resources, enabling scalable and consistent infrastructure deployment. By combining cloud computing with DevSecOps practices, organizations can achieve secure, reliable, and automated software delivery.

II. PROPOSED SYSTEM

The proposed system implements a **DevSecOps CI/CD pipeline** that integrates security throughout the software development lifecycle. Developers push code to **GitHub**, which triggers automated build and testing through **Jenkins**. **SonarQube** performs static code analysis to detect vulnerabilities, while **OWASP ZAP** and **Trivy** scan applications and container images for security issues. The application is containerized using **Docker** and deployed using **Kubernetes** for scalable management. Monitoring tools like **Prometheus** and **Grafana** track system performance and security metrics, helping detect vulnerabilities early and ensure secure software deployment.

III. RESULTS AND DISCUSSION

The implementation of the Secure DevOps pipeline demonstrates the effectiveness of integrating security tools into the CI/CD workflow. Automated security scanning using SonarQube, OWASP ZAP, and Trivy helps detect vulnerabilities during the development and deployment stages. This reduces the risk of security issues in the final application. Containerization using Docker ensures consistent environments across development and deployment, while Kubernetes enables efficient management and scaling of containerized applications. Monitoring tools such as Prometheus and Grafana provide real-time insights into system performance and security metrics. The results show that integrating security into the DevOps pipeline improves application reliability, reduces deployment risks, and enables faster identification and resolution of vulnerabilities.

IV. CONCLUSION

This paper presented the implementation of a Secure DevOps (DevSecOps) CI/CD pipeline that integrates security practices into the software development lifecycle. By incorporating automated security tools such as SonarQube, OWASP ZAP, and Trivy, vulnerabilities can be detected early during development and deployment stages.

The use of Docker and Kubernetes enables efficient containerized deployment, while Terraform automates infrastructure provisioning in the cloud environment. Monitoring tools such as Prometheus and Grafana provide continuous monitoring and visualization of system performance.

The proposed Secure DevOps pipeline improves application security, reliability, and deployment efficiency by integrating security testing and monitoring into the CI/CD workflow. Future work may focus on integrating advanced security analytics and automated threat detection to further enhance system security.

ACKNOWLEDGMENTS

The authors would like to express their sincere gratitude to the Department of Computer Science and Engineering at Global Academy of Technology, Bengaluru, India, for providing the necessary support and facilities to carry out this research work. The authors are especially thankful to **Prof. Sameena H. S., Assistant Professor**, for her continuous guidance, valuable suggestions, and encouragement throughout the development of this project. Her support and insights have greatly contributed to the successful completion of this work.

REFERENCES

- [1] M. Marandi, A. Bertia, and S. Silas, "Implementing and Automating Security Scanning to a DevSecOps CI/CD Pipeline," in *Proc. 2023 World Conf. Communication & Computing (WCONF)*, Raipur, India, Jul. 2023, doi: 10.1109/WCONF58270.2023.10235015.
- [2] M. Voggenteiter, F. Angermeier, F. Moyón, U. Schöpp, and P. Bonvin, "Automated Security Findings Management: A Case Study in Industrial DevOps," in *Proc. 46th Int. Conf. Software Engineering: Software Engineering in Practice (ICSE-SEIP)*, Apr. 2024, doi: 10.1145/3639477.3639744.
- [3] A. Nayanajith and R. Wickramarachchi, "Challenges Affecting the Successful Adoption of DevOps Practices: A Systematic Literature Review," in *Proc. 4th Int. Conf. Advanced Research in Computing (ICARC)*, 2024, doi: 10.1109/ICARC61713.2024.10499735.
- [4] N. Dinh, V. T. Hoang, B. N. Van, T. H. Huong, H. D. T. Hong, H. N. Trung, and K. T. Trung, "Enhancing Smart Contract Security Through DevSecOps: An Adaptive Approach for Vulnerability Detection," *IEEE Access*, vol. 13, pp. 159454–159520, 2025, doi: 10.1109/ACCESS.2025.3606572.
- [5] R. Ashtagi, Y. Bhalerao, C. Belani, P. Bhalerao, and A. Chawle, "Building Resilient CI/CD Pipelines: A DevOps Security-First Framework," in *Proc. 2025 Int. Conf. Computational, Communication and Information Technology (ICCCIT)*, 2025, doi: 10.1109/ICCCIT62592.2025.10927871.
- [6] R. C. B. Ramos and S. G. Yoo, "Cybersecurity in DevOps Environments: A Systematic Literature Review," *IEEE Access*, vol. 13, pp. 191959–191980, 2025, doi: 10.1109/ACCESS.2025.3582892.
- [7] S. A. Ruk, Y. Mahmood, A. Azmi, N. F. M. Azmi, and S. Gul, "Effort Estimation in Agile and DevOps: A Systematic Literature Review of Stakeholder Dissatisfaction," *IEEE Access*, vol. 13, pp. 167925–167960, 2025, doi: 10.1109/ACCESS.2025.3600321.
- [8] N. S. P. Manja, P. Mathur, and P. B. Honnavalli, "Extensive Review of Threat Models for DevSecOps," *IEEE Access*, vol. 13, pp. 45252–45274, 2025, doi: 10.1109/ACCESS.2025.3547932.
- [9] M. A. Akbar and A. A. Alsanad, "Empirical Investigation of Key Enablers for Secure DevOps Practices," *IEEE Access*, vol. 13, pp. 43698–43710, 2025, doi: 10.1109/ACCESS.2025.3549183.
- [10] J. Ababneh, E. Y. A. Al-Nsour, A. Al-Shaikh, M. R. Al-Mousa, A. Al-Zabin, M. Asassfeh, and H. Abualese, "Enhancing DevOps Continuous Monitoring Phase: Hybrid Intrusion Detection and Ensemble Learning System (HIDELS)," *IEEE Access*, vol. 14, pp. 4733–4755, 2026, doi: 10.1109/ACCESS.2026.3650793.